

NIMBUSGUARD TECHNOLOGIES, INC.

Infrastructure and Operations Security Policy

Cloud Architecture, Network Security, Change Management & Monitoring

Document ID:	NG-INF-006	Version:	4.0
Effective Date:	January 30, 2026	Owner:	VP Operations – James Wright
Classification:	Internal – Confidential	Status:	Approved

1. Cloud Infrastructure

NimbusGuard's production environment is hosted entirely on Amazon Web Services (AWS). The Company does not operate any on-premises data centers. AWS data centers are SOC 2 Type II, ISO 27001, and FedRAMP High certified. NimbusGuard leverages the following AWS regions:

Region	Purpose	Services
us-east-1 (Virginia)	Primary US production	EKS, Aurora, ElastiCache, S3, KMS
us-west-2 (Oregon)	Secondary US production (active-active)	EKS, Aurora replica, ElastiCache, S3
eu-central-1 (Frankfurt)	EU production	EKS, Aurora, ElastiCache, S3, KMS

2. Network Security

Network architecture follows a zero-trust model. Key controls include:

- **VPC Segmentation:** Separate VPCs for production, staging, development, and management. No direct connectivity between environments.
- **Security Groups:** Least-privilege inbound/outbound rules. Default deny all. Changes require peer review and approval in Terraform.
- **Private Subnets:** All application and database tiers run in private subnets with no direct internet access. Outbound traffic routes through NAT gateways with egress filtering.
- **AWS PrivateLink:** Used for all AWS service endpoints to eliminate public internet traversal.
- **WAF:** AWS WAF deployed on all public-facing ALBs with OWASP Core Rule Set, rate limiting, and geo-blocking capabilities.
- **DDoS Protection:** AWS Shield Advanced on all production endpoints.

3. Change Management

All changes to production systems follow a formal change management process:

- **Infrastructure as Code:** All infrastructure is defined in Terraform and stored in Git. No manual changes to production are permitted ("no click-ops" policy).
- **Code Review:** All changes require at least two approving reviews from qualified engineers before merge. CODEOWNERS files enforce domain-specific reviewers.
- **CI/CD Pipeline:** Automated pipeline (GitHub Actions) runs unit tests, integration tests, SAST (Semgrep), SCA (Snyk), container scanning (Trivy), and IaC scanning (Checkov) before deployment.
- **Deployment Strategy:** Canary deployments with automated rollback. Changes are deployed to staging first, soaked for 24 hours, then promoted to production.
- **Change Advisory Board:** High-risk changes (database schema, auth system, encryption) require CAB approval. CAB meets weekly and includes CISO, VP Engineering, and VP Operations.

4. Vulnerability Management

NimbusGuard's vulnerability management program includes:

Activity	Tool	Frequency	SLA (Remediation)
Infrastructure scanning	Wiz, AWS Inspector	Continuous	Critical: 24h, High: 7d, Med: 30d
Application DAST	Burp Suite Enterprise	Weekly	Critical: 48h, High: 14d
Static analysis (SAST)	Semgrep	Every commit	Critical: block merge, High: 7d
Dependency scanning (SCA)	Snyk	Every commit + daily	Critical: 24h, High: 7d
Container image scanning	Trivy	Every build + daily	Critical: 24h, High: 7d
External penetration testing	CrowdStrike Services	Annually + major releases	Per finding severity
Bug bounty program	HackerOne	Continuous	Per finding severity

5. Logging and Monitoring

Centralized logging is mandatory for all production systems. Logs are shipped to Splunk Enterprise Security via Fluent Bit agents. Log sources include: application logs, API access logs, AWS CloudTrail (management and data events), VPC Flow Logs, DNS query logs, Kubernetes audit logs, WAF logs, and authentication/authorization events. All logs are retained for a minimum of 13 months in hot storage and 7 years in cold storage (S3 Glacier). Logs are immutable after ingestion (write-once, read-many). Over 850 correlation rules and machine learning models power automated threat detection with a mean time to detect (MTTD) of under 5 minutes for known attack patterns.

6. Asset Management

All assets (physical and virtual) are tracked in ServiceNow CMDB. Cloud assets are automatically discovered and inventoried via AWS Config and Wiz. Unmanaged or non-compliant assets trigger automated alerts. All assets must have an assigned owner, a classification label, and a defined lifecycle. Decommissioned assets undergo cryptographic erasure and are verified before disposal.